

TJSC 2026 - Analista de Sistemas

Segurança da Informação e Governança de TI

Aula 2 - Proteção de dados pessoais e LGPD aplicada a sistemas e ambiente público

Escopo desta aula

Trilha coberta: Aula 2 - Proteção de dados pessoais e Lei Geral de Proteção de Dados Pessoais (LGPD) aplicada a sistemas corporativos, APIs, bases de dados, logs, integrações, transparência e ambiente público.

Edital: Segurança da Informação e Governança de TI - item 1.2 Proteção de dados pessoais e item 2 Lei nº 13.709/2018 - Lei Geral de Proteção de Dados Pessoais.

Foco FGV: conceitos legais próximos, situações de órgão público, agentes de tratamento, bases legais, princípios, direitos do titular, dados sensíveis, anonimização, compartilhamento e segurança aplicada.

Material autoral, orientado ao edital retificado do TJSC 2026 e ao padrão de cobrança da Fundação Getulio Vargas (FGV). As questões são inéditas; provas reais foram usadas apenas para calibrar formato, vocabulário e nível de discriminação.

1. Direcionamento da aula

Esta aula trata de proteção de dados pessoais e LGPD aplicada a sistemas e ao ambiente público. O edital não pede um curso jurídico completo de privacidade; pede que o candidato de TI saiba reconhecer quando um dado pessoal está sendo tratado, quais regras básicas protegem esse tratamento e como isso aparece em sistemas corporativos, APIs, logs, bases de dados, integrações e governança pública.

Para o TJSC, o ponto mais provável não é decorar todos os artigos da lei. O retorno maior está em dominar: conceitos do art. 5º, princípios do art. 6º, bases legais dos arts. 7º e 11, regras do Poder Público no art. 23, papel do encarregado no art. 41, segurança e responsabilização nos arts. 44 e 50, além de anonimização, pseudonimização, compartilhamento e direitos do titular.

Cuidado de rota

Aula 2 não é uma aula de criptografia, PKI, OWASP ou OAuth2. Esses temas podem aparecer como instrumentos de proteção, mas o núcleo aqui é LGPD, proteção de dados pessoais e sua aplicação em sistemas públicos.

1.1 Como estudar em blocos curtos

Bloco 1 - 35 min: conceitos, agentes e princípios. Bloco 2 - 40 min: bases legais, dados sensíveis e Poder Público. Bloco 3 - 35 min: aplicação em sistemas, APIs, logs, testes, backup e compartilhamento. Bloco 4 - 50 min: resolva as 20 questões sem olhar o gabarito e corrija com atenção às alternativas sedutoras.

1.2 Como a FGV costuma cobrar LGPD em TI

Em provas de Tecnologia da Informação, a FGV costuma transformar a LGPD em cenário: órgão público que compartilha dados, sistema legado com dados antigos, auditoria de conformidade, base de dados usada para BI, dado biométrico em autenticação, logs de acesso, encarregado de dados ou tratamento automatizado. A banca raramente pergunta só 'o que é dado pessoal?'; ela força o candidato a distinguir conceito verdadeiro aplicado em contexto errado.

O padrão de questão mais perigoso é a alternativa parcialmente correta: por exemplo, afirmar que consentimento sempre resolve tratamento público; que anonimização e pseudonimização são equivalentes; que dado público pode ser usado para qualquer finalidade; que o operador decide finalidades; ou que segurança da informação substitui base legal.

2. Conceitos essenciais da LGPD

A Lei Geral de Proteção de Dados Pessoais - LGPD, Lei nº 13.709/2018, dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural ou por pessoa jurídica de direito público ou privado. Seu objetivo é proteger direitos fundamentais de liberdade, privacidade e livre desenvolvimento da personalidade da pessoa natural.

2.1 Dado pessoal

Dado pessoal é informação relacionada a **pessoa natural identificada ou identificável**. A palavra-chave é pessoa natural. CNPJ, nome empresarial e dado puramente institucional de pessoa jurídica não são, por si só, dados pessoais. Mas um e-mail corporativo do tipo nome.sobrenome@orgao.gov.br pode identificar uma pessoa natural e, portanto, pode ser dado pessoal.

Exemplos em sistemas: nome, CPF, e-mail nominativo, telefone, matrícula funcional vinculada a servidor, endereço IP quando relacionado a usuário identificável, identificador de sessão que permita rastrear uma pessoa, geolocalização, foto, voz, logs vinculados a uma conta e identificadores de dispositivo.

2.2 Dado pessoal sensível

Dado pessoal sensível é uma categoria com proteção reforçada. A LGPD lista: **origem racial ou étnica**, convicção religiosa, opinião política, filiação a sindicato ou a organização religiosa, filosófica ou política, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural.

Em TI, dado biométrico em login facial, impressão digital, reconhecimento de voz ou controle de acesso físico é ponto clássico. Não confunda: biometria não é 'apenas método de autenticação'. Quando vinculada a uma pessoa natural, é dado pessoal sensível.

2.3 Dado anonimizado e pseudonimizado

Dado anonimizado é dado relativo a titular que não possa ser identificado, considerando meios técnicos razoáveis e disponíveis na ocasião do tratamento. A LGPD diz que dados anonimizados **não são considerados dados pessoais, salvo quando o processo de anonimização puder ser revertido com meios próprios ou esforços razoáveis**.

Pseudonimização é diferente: o dado **perde a associação direta ou indireta a um indivíduo**, salvo pelo uso de informação adicional mantida separadamente, em ambiente controlado e seguro. Na prática: substituir CPF por um código aleatório e guardar a tabela de correspondência em cofre separado reduz risco, mas não transforma automaticamente o conjunto em dado anônimo. Em regra, dado pseudonimizado ainda deve ser tratado como dado pessoal.

Conceito	Ideia	Exemplo	Pegadinha FGV
Dado pessoal	Identifica ou pode identificar pessoa natural	CPF, e-mail nominativo, IP vinculado a usuário	Não precisa identificar diretamente; identificável também conta
Dado sensível	Dado pessoal com risco especial de discriminação ou impacto	Biometria, saúde, religião, origem racial	Biometria de autenticação é dado sensível
Anonimizado	Não permite identificação com meios razoáveis	Dataset estatístico sem reidentificação razoável	Se reversível, volta ao regime de dado pessoal
Pseudonimizado	Identificador substituído, com chave separada	CPF trocado por token interno	Reduz risco, mas não equivale a anonimização

2.4 Titular, tratamento e banco de dados

Titular é a pessoa natural a quem se referem os dados pessoais. Tratamento é praticamente qualquer operação com dados pessoais: coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação, modificação, comunicação, transferência, difusão ou extração.

Banco de dados, na LGPD, é conjunto estruturado de dados pessoais, estabelecido em um ou vários locais, em suporte eletrônico ou físico. Isso derruba a ideia de que LGPD só vale para banco relacional. Uma planilha, um data lake, um índice de busca, logs estruturados, backups, documentos digitais e até fichas físicas podem se enquadrar.

3. Princípios da proteção de dados

Os princípios do art. 6º são a espinha dorsal das questões de LGPD. Mesmo quando uma base legal existe, o tratamento deve respeitar boa-fé e princípios. Em prova, a banca gosta de dar uma situação com base legal aparente, mas violação de finalidade, necessidade, transparência ou segurança.

Princípio	Sentido de prova	Exemplo em sistema
Finalidade	Propósito legítimo, específico, explícito e informado	Coletar CPF para identificar parte processual, não para campanha irrelevante

Princípio	Sentido de prova	Exemplo em sistema
Adequação	Compatibilidade do tratamento com a finalidade informada	Uso de e-mail para comunicação processual prevista, não para finalidade incompatível
Necessidade	Mínimo necessário, dados pertinentes e proporcionais	Não exigir biometria facial para consulta que poderia usar autenticação comum
Livre acesso	Consulta facilitada e gratuita sobre forma, duração e dados	Portal informa dados tratados e permite solicitação
Qualidade dos dados	Exatidão, clareza, relevância e atualização	Corrigir cadastro desatualizado que prejudica intimação
Transparência	Informações claras sobre tratamento e agentes	Aviso de privacidade em linguagem objetiva
Segurança	Medidas técnicas e administrativas contra acesso não autorizado e incidentes	Controle de acesso, logs, criptografia em trânsito, segregação
Prevenção	Adoção de medidas para evitar dano	Avaliar risco antes de integrar sistemas
Não discriminação	Vedação de fins discriminatórios ilícitos ou abusivos	Não usar perfilamento para negar acesso indevido a serviço
Responsabilização e prestação de contas	Demonstrar medidas eficazes de conformidade	Registro das decisões, políticas, evidências e auditoria

Pegadinha de alto ROI

Base legal não apaga princípio. Um órgão pode ter competência para tratar dados, mas ainda deve limitar coleta, informar finalidades, proteger os dados e demonstrar conformidade.

3.1 Finalidade, adequação e necessidade

Esses três princípios aparecem juntos em cenários de sistema. Finalidade pergunta 'para quê?'; adequação pergunta 'isso combina com a finalidade?'; necessidade pergunta 'preciso mesmo desse dado, nessa extensão, por esse tempo?'.
Exemplo: um sistema de agendamento interno exige nome, CPF, e-mail, telefone e unidade. Se também exige religião e biometria facial sem justificativa, o problema não é apenas segurança; é excesso e possível tratamento de dado sensível sem base adequada.

3.2 Segurança, prevenção e accountability

Segurança é proteção contra acessos não autorizados e eventos acidentais ou ilícitos. Prevenção é postura anterior ao dano: avaliar riscos, definir controles, limitar acessos, testar hipóteses de incidente. Responsabilização e prestação de contas significam demonstrar conformidade, e não apenas alegar boa intenção.

4. Bases legais: quando o tratamento pode ocorrer

A LGPD não proíbe tratamento de dados pessoais; ela condiciona o tratamento a hipóteses legais e princípios. Em prova, cuidado com alternativas absolutas: 'sempre depende de consentimento', 'nunca depende de consentimento', 'basta anonimizar depois', 'basta criptografar'. Essas frases normalmente estão erradas.

4.1 Bases legais para dados pessoais comuns

O art. 7º traz hipóteses como **consentimento**, **obrigação legal** ou **regulatória**, **execução de políticas públicas** pela administração pública, **estudos** por órgão de pesquisa, **execução de contrato**, **exercício regular de direitos**, **proteção da vida**, **tutela da saúde**, **legítimo interesse** e **proteção do crédito**.

Para ambiente público, a base mais relevante costuma ser a execução de políticas públicas ou cumprimento de competências legais, e não consentimento como regra. No Poder Judiciário, muitos tratamentos decorrem de atribuições legais, gestão processual, prestação jurisdicional, gestão

administrativa e cumprimento de obrigações normativas.

4.2 Consentimento

Consentimento é manifestação livre, informada e inequívoca pela qual o titular concorda com tratamento para finalidade determinada. Deve ser destacado quando escrito, e autorizações genéricas são nulas. O controlador tem o ônus de provar que o consentimento foi obtido corretamente.

No setor público, consentimento pode existir, mas a FGV tende a cobrar que ele não é a base universal. Quando há cumprimento de obrigação legal, execução de política pública ou competência institucional, exigir consentimento como se o titular pudesse livremente impedir a atuação estatal pode ser inadequado.

4.3 Dados sensíveis

Dados sensíveis possuem rol próprio de hipóteses no art. 11. A regra de prova é: não basta aplicar automaticamente as mesmas bases de dados comuns. Para dado sensível, há consentimento específico e destacado ou hipóteses sem consentimento quando indispensáveis, como obrigação legal/regulatória, políticas públicas previstas em lei ou regulamento, estudos por órgão de pesquisa, exercício regular de direitos, proteção da vida, tutela da saúde e prevenção à fraude e segurança do titular em identificação e autenticação eletrônica.

Situação	Base/ideia provável	Cuidado de prova
Cadastro de usuários de sistema administrativo	Competência legal, obrigação regulatória ou execução de serviço público	Não dizer que sempre depende de consentimento
Biometria para autenticação	Dado sensível; pode envolver prevenção à fraude e segurança do titular, com necessidade e proporcionalidade	Não tratar como simples credencial sem LGPD
Sistema legado com clientes/partes inativas	Verificar finalidade, prazo, obrigação legal, arquivo e necessidade	Guardar 'para sempre' sem justificativa viola necessidade
Logs de acesso vinculados a usuários	Segurança, auditoria, obrigação e legítima finalidade	Log também pode conter dado pessoal
Uso de dados públicos	Deve respeitar finalidade, boa-fé e interesse público da divulgação	Dado público não é dado livre para qualquer uso

5. Agentes de tratamento e papéis

A FGV cobra papéis. Controlador decide sobre o tratamento; operador realiza tratamento em nome do controlador; encarregado atua como canal de comunicação entre controlador, titulares e Autoridade Nacional de Proteção de Dados - ANPD. Agentes de tratamento são controlador e operador; o encarregado não é agente de tratamento.

Papel	O que faz	Exemplo TJSC/sistema
Titular	Pessoa natural a quem os dados se referem	Servidor, jurisdicionado, advogado, parte, candidato
Controlador	Toma decisões sobre finalidade e meios essenciais do tratamento	Órgão que define tratamento para sistema institucional
Operador	Trata dados em nome do controlador, conforme instruções	Fornecedor que hospeda, processa ou suporta sistema sob contrato
Encarregado	Canal com titulares e ANPD; orienta internamente	DPO/encarregado divulgado no sítio do controlador
ANPD	Zela, implementa e fiscaliza a LGPD	Pode solicitar informações, RIPD e recomendar medidas

5.1 Controlador x operador

A distinção não depende do nome no contrato, mas da realidade do tratamento. Se uma empresa apenas processa dados seguindo instruções do órgão, tende a ser operadora. Se define finalidade e meios essenciais do tratamento, pode ser controladora ou controladora conjunta, conforme o caso.

Em arquitetura corporativa: o órgão público pode ser controlador de dados de usuários de um sistema; uma empresa de nuvem ou fábrica de software pode ser operadora; outro órgão que recebe dados para finalidade própria pode ser controlador independente. A palavra 'terceirizado' não resolve sozinha.

5.2 Encarregado

O encarregado deve aceitar reclamações e comunicações dos titulares, receber comunicações da ANPD, orientar funcionários e contratados sobre práticas de proteção de dados e executar outras atribuições determinadas pelo controlador ou por normas complementares. A identidade e os contatos do encarregado devem ser divulgados publicamente de forma clara e objetiva, preferencialmente no sítio eletrônico do controlador.

Ponto que seduz em prova

O encarregado não 'manda' no banco de dados e não substitui o controlador. Ele atua como canal, orienta e apoia governança. A decisão sobre finalidade e meios essenciais é do controlador.

6. LGPD no Poder Público

O Poder Público tem regras próprias. Segundo orientação da ANPD, o conceito de Poder Público é amplo e abrange órgãos e entidades dos entes federativos e dos três Poderes, inclusive o Judiciário. Isso torna a aula diretamente conectada ao TJSC.

6.1 Finalidade pública e interesse público

O tratamento pelo Poder Público deve ocorrer para atendimento de finalidade pública, na persecução do interesse público, com objetivo de executar competências legais ou cumprir atribuições legais do serviço público. Em prova, isso aparece como cadastro de jurisdicionados, tramitação processual, gestão documental, atendimento ao cidadão, transparência ativa, auditoria, segurança institucional e integração entre órgãos.

A banca pode tentar afirmar que órgão público 'dispensa LGPD' porque exerce função pública. **Errado.** O Poder Público deve observar LGPD, salvo hipóteses específicas de não aplicação ou legislação específica, e deve cumprir publicidade, finalidade, necessidade e segurança.

6.2 Transparência pública

O art. 23 exige que sejam informadas as hipóteses em que, no exercício de competências, realizam tratamento de dados pessoais, com informações claras e atualizadas sobre previsão legal, finalidade, procedimentos e práticas utilizadas, em veículos de fácil acesso, preferencialmente em sítios eletrônicos.

Isso conversa com sistemas públicos: inventário de tratamento, aviso de privacidade, página de LGPD, indicação do encarregado, política de retenção, controles de acesso, registro de compartilhamentos e linguagem compreensível ao titular.

6.3 Compartilhamento e comunicação de dados

Uso compartilhado envolve comunicação, difusão, transferência internacional, interconexão de dados pessoais ou tratamento compartilhado de bancos de dados pessoais por órgãos e entidades públicos no cumprimento de suas competências legais, ou entre estes e entes privados nas hipóteses permitidas.

Em prova, cuidado: compartilhamento não é proibido por si só, mas exige finalidade, base legal, transparência, compatibilidade, segurança e respeito às competências. Também não se resolve

simplesmente por 'ter contrato' ou 'ser órgão público'.

6.4 LGPD e Lei de Acesso à Informação

A LGPD **não revoga a transparência pública** nem a **Lei de Acesso à Informação** - LAI. O desafio é compatibilizar publicidade e proteção de dados. Dados pessoais podem aparecer em atos públicos quando houver base legal e finalidade pública, mas a divulgação deve observar necessidade, proporcionalidade e eventual restrição de dados sensíveis, crianças/adolescentes, segredo de justiça ou risco ao titular.

FGV gosta desta tensão

Não escolha extremos: 'todo dado pessoal deve ser ocultado' e 'todo dado público pode ser exposto livremente' costumam estar errados. A resposta correta tende a equilibrar publicidade, finalidade, base legal, necessidade e proteção.

7. Direitos do titular e decisões automatizadas

A LGPD garante direitos ao titular, como confirmação da existência de tratamento, acesso aos dados, correção de dados incompletos, inexatos ou desatualizados, anonimização, bloqueio ou eliminação de dados desnecessários ou tratados em desconformidade, portabilidade, informação sobre compartilhamento, informação sobre possibilidade de não consentir, revogação do consentimento e oposição em hipóteses legais.

Em ambiente público, esses direitos existem, mas podem ser compatibilizados com deveres legais, guarda documental, processo judicial, transparência pública, segurança e interesse público. A eliminação não é automática se há obrigação legal de conservação, exercício regular de direitos, arquivo público ou outra base de conservação.

7.1 Decisões automatizadas

O titular tem direito a solicitar revisão de decisões tomadas unicamente com base em tratamento automatizado de dados pessoais que afetem seus interesses, inclusive decisões destinadas a definir perfil pessoal, profissional, de consumo e de crédito ou aspectos de sua personalidade.

Em sistemas públicos, isso pode aparecer em triagem automatizada, classificação de risco, priorização automática, detecção de fraude, cruzamento de bases e analytics. A questão pode cobrar transparência, auditoria, não discriminação e explicabilidade sem exigir uma aula de inteligência artificial.

8. Proteção de dados aplicada a sistemas, APIs e ambiente bancário/público

8.1 Ciclo de vida dos dados

Para um desenvolvedor, a LGPD fica mais fácil quando vista como ciclo de vida: coleta, validação, armazenamento, uso, compartilhamento, arquivamento, retenção e eliminação. Cada fase pede justificativa de finalidade, base legal, necessidade e controles.

Fase	Pergunta de conformidade	Controle prático
Coleta	Por que esse dado é necessário?	Formulário mínimo, campos justificados, aviso claro
Armazenamento	Quem acessa e por quanto tempo?	RBAC, criptografia, segregação, trilha de auditoria
Uso	O uso é compatível com a finalidade?	Controle de finalidade, logs, revisão de permissões

Fase	Pergunta de conformidade	Controle prático
Compartilhamento	Com quem, para quê e com qual base?	Contrato, registro, API gateway, escopo mínimo
Teste/desenvolvimento	Há dados reais sem necessidade?	Mascaramento, dados sintéticos, ambientes segregados
Retenção	Existe obrigação ou finalidade ativa?	Tabela de temporalidade e descarte controlado
Eliminação	Pode eliminar ou deve conservar?	Procedimento auditável, exceções legais, backup tratado

8.2 APIs e minimização

Em API REST - Representational State Transfer, proteção de dados começa no contrato. Um endpoint não deve devolver CPF, telefone, e-mail, data de nascimento, endereço, dados sensíveis ou identificadores internos se o consumidor não precisa deles. O problema de LGPD pode estar no JSON de resposta, no payload de requisição, no log de erro, no cache, no evento de mensageria ou no relatório exportado.

Exemplo: GET /usuarios/{id}/perfil usado por um front-end Angular para exibir nome e lotação. Se a API retorna CPF, salário, dados de saúde e tokens internos 'por conveniência', viola necessidade e aumenta superfície de vazamento.

8.3 Logs, auditoria e rastreabilidade

Logs são necessários para segurança e auditoria, mas podem conter dados pessoais. Registrar CPF completo, token de sessão, Authorization header, dados sensíveis ou payload integral sem necessidade cria risco. A solução não é apagar todos os logs, mas definir finalidade, retenção, mascaramento, segregação de acesso e trilha de auditoria.

Regra prática de prova: log pode ser dado pessoal; log é controle de segurança; log sem governança pode virar risco de privacidade.

8.4 Ambientes de desenvolvimento, teste e homologação

Copiar base de produção para desenvolvimento com dados reais de titulares é um erro recorrente. Quando necessário, deve haver base legal, controle de acesso, mascaramento, pseudonimização ou dados sintéticos. Em sistemas Java/Quarkus e Angular, isso envolve seed controlado, migrations, mocks, stubs, contratos de API e ambientes segregados.

8.5 Backup, retenção e sistemas legados

Backups e sistemas legados também estão no escopo de proteção de dados. A existência de backup não autoriza retenção infinita sem política. Por outro lado, pedidos de eliminação devem ser compatibilizados com obrigações legais, retenção processual, auditoria e integridade de backups. O ponto FGV é equilíbrio: nem apagar tudo imediatamente, nem guardar tudo para sempre sem finalidade.

9. Relatório de impacto, segurança e governança

Relatório de Impacto à Proteção de Dados Pessoais - RIPD é documentação do controlador que **descreve processos de tratamento que podem gerar riscos às liberdades civis e aos direitos fundamentais, bem como medidas, salvaguardas e mecanismos de mitigação.** A Autoridade Nacional pode solicitar o relatório em situações previstas na LGPD.

Em prova, RIPD costuma se ligar a **tratamento de alto risco**, dados sensíveis, larga escala, perfilamento, integração entre bases, decisões automatizadas ou compartilhamento relevante. Não é mero log técnico; é documento de governança e risco.

9.1 Segurança técnica e administrativa

A LGPD exige medidas técnicas e administrativas aptas a proteger dados pessoais. Técnicas: controle de acesso, criptografia em trânsito, hashing de senhas, segregação de ambientes, tokenização, monitoramento, gestão de vulnerabilidades, mascaramento e backup seguro. Administrativas: políticas, treinamento, contratos, gestão de fornecedores, matriz de responsabilidades, resposta a incidentes e auditoria.

Atenção: criptografia, hashing e controles de acesso reduzem risco, mas não substituem base legal e princípios. Um tratamento desnecessário não fica automaticamente legítimo porque está criptografado.

9.2 Incidente de segurança

Incidente de segurança envolvendo dados pessoais é evento que pode acarretar risco ou dano relevante aos titulares. A resposta deve considerar contenção, avaliação de impacto, comunicação quando cabível, evidências, medidas corretivas e prevenção de recorrência. Para prova, ligue incidente a segurança, prevenção, accountability, risco e eventual comunicação à ANPD e aos titulares, conforme gravidade e regras aplicáveis.

10. Pegadinhas FGV consolidadas

Pegadinha	Correção
Consentimento sempre é necessário	Não. É uma das bases legais. No setor público, muitas vezes há competência legal, obrigação ou política pública.
Dado público é livre	Não. Deve respeitar finalidade, boa-fé e interesse público que justificaram a divulgação.
Anonimização = pseudonimização	Não. Pseudonimização mantém possibilidade de associação com informação adicional.
Operador decide a finalidade	Não em regra. Operador trata em nome do controlador e conforme instruções.
Encarregado é agente de tratamento	Não. Agentes de tratamento são controlador e operador.
LGPD não se aplica ao Judiciário	Aplica-se ao Poder Público, ressalvadas exceções e regras específicas.
Segurança da informação basta para LGPD	Não. Segurança é princípio/controlar; também há bases legais, direitos, transparência e necessidade.
Dados sensíveis só existem em saúde	Não. Biometria, religião, origem racial, opinião política e outros também são sensíveis.
Pedido de eliminação sempre deve ser atendido imediatamente	Não se houver obrigação legal, exercício de direitos, arquivo ou outra hipótese de conservação.
Log é puramente técnico	Pode conter dados pessoais e exige governança.

10.1 Checklist do que memorizar

- Dado pessoal = pessoa natural identificada ou identificável.
- Dado sensível inclui biometria quando vinculada a pessoa natural.
- Tratamento é conceito amplíssimo: coletar, acessar, armazenar, compartilhar, eliminar etc.
- Controlador decide; operador executa em nome; encarregado comunica e orienta.
- Princípios: finalidade, adequação, necessidade, livre acesso, qualidade, transparência, segurança, prevenção, não discriminação e accountability.
- Consentimento não é base universal, especialmente no setor público.

- Poder Público trata dados para finalidade pública, interesse público e competências legais, com transparência.
- Anonimização forte pode tirar dado do escopo; pseudonimização reduz risco, mas geralmente continua no regime da LGPD.
- Segurança técnica não substitui base legal e princípios.
- Em sistemas: cuidado com APIs, logs, testes, backups, integrações, BI e legados.

11. Lista de questões autorais - padrão FGV

Instruções: resolva as 20 questões sem consultar o gabarito. As alternativas foram construídas para evitar respostas óbvias; muitas contêm conceitos verdadeiros aplicados fora do contexto.

Questão 1

Durante a revisão de um sistema interno de um tribunal, a equipe técnica identificou que um endpoint utilizado pelo front-end Angular retornava, além do nome e da unidade de lotação do servidor, CPF, endereço residencial, telefone pessoal e identificadores internos de auditoria, embora a tela exibisse apenas nome e unidade. Considerando a LGPD e os princípios aplicáveis, a análise mais adequada é a de que:

- A) não há irregularidade se o endpoint for acessado por HTTPS - Hypertext Transfer Protocol Secure, pois a criptografia em trânsito afasta a incidência dos princípios da LGPD.
- B) a situação viola necessariamente o princípio da transparência, mas não o da necessidade, pois os dados permanecem dentro do órgão público.
- C) há risco de violação ao princípio da necessidade, pois o tratamento deve limitar-se ao mínimo necessário para a finalidade pretendida.
- D) a situação somente seria problemática se os dados fossem sensíveis, já que dados cadastrais comuns não são protegidos pela LGPD.
- E) a adequação do endpoint depende exclusivamente do consentimento do servidor, sem necessidade de avaliar finalidade institucional.

Questão 2

Um fornecedor contratado para sustentação de um sistema do Poder Judiciário acessa dados pessoais apenas para executar rotinas de manutenção definidas pelo órgão, sem decidir as finalidades do tratamento nem reutilizar os dados para fins próprios. Nessa hipótese, em regra, o fornecedor atua como:

- A) encarregado pelo tratamento, pois acessa dados pessoais e se comunica com usuários técnicos do sistema.
- B) titular dos dados, pois recebe temporariamente informações pessoais para executar atividade de suporte.
- C) controlador independente, pois todo terceiro que acessa dado pessoal decide automaticamente sobre o tratamento.
- D) operador, pois realiza tratamento em nome do controlador, segundo suas instruções.
- E) autoridade nacional setorial, pois fiscaliza a conformidade técnica do sistema contratado.

Questão 3

Analise as afirmativas sobre anonimização e pseudonimização. I. Dados anonimizados não são considerados dados pessoais quando o titular não puder ser identificado por meios técnicos razoáveis e disponíveis. II. Na pseudonimização, a possibilidade de associação pode subsistir por meio de informação adicional mantida separadamente. III. Todo dado pseudonimizado deixa de se submeter à LGPD, ainda que haja chave de reversão mantida pelo controlador. Está correto o que se afirma em:

- A) I, apenas.
- B) I e II, apenas.
- C) II e III, apenas.
- D) I e III, apenas.
- E) I, II e III.

Questão 4

Um órgão público pretende tratar dados pessoais para executar atribuição legal relacionada à prestação de serviço público, com divulgação clara da finalidade, da previsão legal e dos procedimentos em seu sítio eletrônico. À luz da LGPD, é correto afirmar que:

- A) o tratamento pelo Poder Público é dispensado de qualquer observância à LGPD quando houver interesse público.
- B) o consentimento do titular é sempre a única base legal possível para a Administração Pública tratar dados pessoais.
- C) o tratamento pode ser compatível com a LGPD, desde que atenda à finalidade pública, ao interesse público, às competências legais e aos princípios aplicáveis.
- D) a publicação da finalidade em sítio eletrônico elimina a necessidade de adotar controles técnicos de segurança.
- E) a LGPD somente se aplica à Administração Pública quando houver compartilhamento com empresas privadas.

Questão 5

Relacione os conceitos da coluna I às descrições da coluna II. Coluna I: 1. Controlador; 2. Operador; 3. Encarregado; 4. Titular. Coluna II: () Pessoa natural a quem se referem os dados pessoais. () Pessoa ou entidade a quem competem as decisões referentes ao tratamento. () Pessoa ou entidade que realiza tratamento em nome do controlador. () Canal de comunicação com titulares e autoridade nacional. A sequência correta é:

- A) 4 - 1 - 2 - 3.
- B) 1 - 4 - 2 - 3.
- C) 4 - 2 - 1 - 3.
- D) 3 - 1 - 2 - 4.
- E) 2 - 1 - 3 - 4.

Questão 6

Uma equipe de desenvolvimento deseja copiar a base de produção de um sistema de atendimento ao cidadão para o ambiente local de testes, mantendo nomes, CPFs, telefones, endereços e histórico de solicitações, sob o argumento de que isso acelera a reprodução de bugs. A medida mais alinhada à proteção de dados pessoais é:

- A) copiar a base integralmente, pois ambiente de desenvolvimento não caracteriza tratamento de dados pessoais.
- B) substituir a base por dados sintéticos ou aplicar mascaramento/pseudonimização adequada, restringindo acessos e justificando eventual uso de dados reais.
- C) manter os dados reais e apagar apenas os CPFs, pois os nomes isolados nunca identificam pessoas naturais.
- D) liberar a cópia a todos os desenvolvedores, desde que cada um assine termo de confidencialidade, dispensando controles técnicos.
- E) exportar a base para planilhas, pois arquivos locais não se enquadram no conceito de banco de dados da LGPD.

Questão 7

Assinale a opção que apresenta dado pessoal sensível, nos termos da LGPD, quando vinculado a uma pessoa natural.

- A) Número de protocolo administrativo.
- B) Endereço de e-mail institucional genérico de uma unidade.
- C) Nome de usuário técnico sem associação a pessoa natural.
- D) Dado biométrico usado para autenticação de cadastro em sistema eletrônico.
- E) Código interno aleatório que não pode ser associado ao titular por meios razoáveis.

Questão 8

Um sistema público usa logs de auditoria para registrar acessos a processos e documentos. Os logs contêm matrícula do usuário, IP de origem, data, hora, ação executada e identificador do documento acessado. Sobre esses logs, é correto afirmar que:

- A) não podem conter dado pessoal em nenhuma hipótese, pois logs são dados exclusivamente técnicos.
- B) podem conter dados pessoais e devem ser tratados com finalidade, retenção, controle de acesso e segurança adequados.
- C) devem ser eliminados imediatamente após o acesso, pois a LGPD veda armazenamento de rastros de auditoria.
- D) dispensam qualquer política de retenção, pois quanto maior o histórico, maior a conformidade.
- E) só são regulados pela LGPD se houver dados pessoais sensíveis, como saúde ou biometria.

Questão 9

No contexto da LGPD, assinale a alternativa incorreta.

- A) O tratamento de dados pessoais pode ocorrer em meios digitais ou físicos.
- B) A dispensa de consentimento não desobriga o agente de observar princípios e direitos do titular.
- C) O tratamento de dados tornados manifestamente públicos pelo titular deve observar finalidade, boa-fé e interesse público.
- D) O dado pessoal é sempre informação relacionada a pessoa jurídica identificada ou identificável.
- E) O tratamento inclui operações como coleta, acesso, armazenamento, compartilhamento e eliminação.

Questão 10

Um tribunal contrata solução de análise estatística para produzir indicadores públicos de produtividade. Antes da publicação, os dados são agregados por unidade judiciária e período, sem permitir identificação de magistrados, servidores, partes ou advogados por meios razoáveis. A interpretação mais adequada é que:

- A) a anonimização ou agregação efetiva pode afastar o regime de dado pessoal, desde que não haja reidentificação razoável.
- B) todo dado derivado de base pessoal permanece necessariamente dado pessoal, mesmo quando não identificável por meios razoáveis.
- C) a publicação é sempre ilícita, pois qualquer estatística pública viola a titularidade dos dados.
- D) a agregação substitui integralmente a necessidade de avaliar finalidade, segurança e risco do tratamento anterior.
- E) a anonimização é irrelevante para a LGPD, que protege qualquer dado produzido por órgão público.

Questão 11

Em um projeto de integração entre dois órgãos públicos, a equipe técnica pretende compartilhar dados pessoais por API - Application Programming Interface. A alternativa mais adequada à LGPD é:

- A) permitir o compartilhamento amplo, pois órgãos públicos podem trocar qualquer dado quando ambos integram a Administração Pública.
- B) condicionar o compartilhamento apenas à existência de criptografia TLS - Transport Layer Security, sem avaliar finalidade ou competência.
- C) restringir o compartilhamento à finalidade pública e às competências legais, com transparência, escopo mínimo, segurança e registro da operação.
- D) exigir sempre consentimento individual de todos os titulares, mesmo quando a comunicação decorre de obrigação legal expressa.
- E) proibir toda comunicação de dados pessoais entre órgãos, salvo decisão judicial individualizada.

Questão 12

Uma organização pública pretende indicar o encarregado pelo tratamento de dados pessoais. Segundo a LGPD, dentre as atividades típicas do encarregado está:

- A) decidir sozinho as finalidades do tratamento realizado pelo órgão.
- B) substituir o operador na execução técnica das rotinas de tratamento.
- C) aceitar reclamações e comunicações dos titulares, receber comunicações da ANPD e orientar funcionários e contratados sobre proteção de dados.
- D) fiscalizar a ANPD em nome do controlador.

E) aprovar previamente todos os scripts SQL executados em ambiente de produção.

Questão 13

Uma equipe argumenta que a implementação de criptografia em repouso na base de dados torna dispensável qualquer análise de base legal para o tratamento de dados pessoais. Essa afirmação está:

- A) correta, pois controles de segurança substituem a necessidade de fundamento jurídico para o tratamento.
- B) correta apenas quando os dados forem armazenados em ambiente público de nuvem.
- C) incorreta, pois segurança é medida relevante, mas não substitui base legal, finalidade, necessidade e demais princípios.
- D) incorreta somente se houver dados de crianças, pois para adultos a criptografia é suficiente.
- E) correta se a chave criptográfica for armazenada em Hardware Security Module - HSM.

Questão 14

Uma base de dados de um sistema legado contém dados pessoais de usuários inativos há mais de dez anos. Não há documentação sobre finalidade atual, prazo de guarda, base legal ou obrigação de conservação. A conduta mais compatível com a LGPD é:

- A) manter a base integralmente por prazo indeterminado, pois dados antigos têm baixo risco de privacidade.
- B) eliminar todos os registros imediatamente, sem avaliar obrigações legais, preservação documental ou exercício regular de direitos.
- C) publicar a base em formato aberto para dar transparência ao histórico do sistema.
- D) avaliar finalidade, necessidade, bases de conservação, temporalidade, riscos e medidas como eliminação, anonimização ou restrição de acesso.
- E) transferir a base para ambiente de backup, pois backups não se submetem à LGPD.

Questão 15

Sobre dados pessoais de crianças e adolescentes, assinale a opção mais adequada.

- A) O tratamento deve observar o melhor interesse da criança e do adolescente, e o tratamento de dados de crianças exige consentimento específico e em destaque de pelo menos um dos pais ou responsável legal, ressalvadas as hipóteses legais aplicáveis.
- B) A LGPD não trata de crianças e adolescentes, pois esse assunto pertence exclusivamente ao Estatuto da Criança e do Adolescente.
- C) Dados de crianças podem ser livremente tratados por órgão público sem transparência, desde que a finalidade seja administrativa.
- D) Dados de adolescentes são sempre considerados anônimos para fins de sistemas públicos.
- E) O melhor interesse é princípio aplicável apenas a aplicativos comerciais, não a sistemas públicos.

Questão 16

Um portal institucional informa em linguagem clara quais dados pessoais são tratados em determinado serviço, a finalidade, a previsão legal, a forma e duração do tratamento, o controlador, contato do encarregado e uso compartilhado de dados. A prática está especialmente relacionada aos princípios de:

- A) portabilidade e proteção do crédito.
- B) transparência e livre acesso.
- C) anonimização e bloqueio.
- D) não discriminação e tutela da saúde.
- E) defesa nacional e segurança pública.

Questão 17

Um analista desenha um relatório de impacto à proteção de dados pessoais para novo sistema que integrará bases de processos, atendimento ao cidadão e autenticação biométrica. O conteúdo esperado desse relatório envolve, principalmente:

- A) descrição dos processos de tratamento que podem gerar riscos, bem como medidas, salvaguardas e mecanismos de mitigação.
- B) relação de todos os servidores públicos do órgão e respectivas senhas de acesso para fins de auditoria.
- C) ata de aprovação do orçamento do projeto, sem análise de riscos aos titulares.
- D) substituição integral da política de segurança da informação do órgão.
- E) autorização genérica para tratar qualquer dado pessoal relacionado ao sistema.

Questão 18

A respeito do uso de dados pessoais de acesso público, conforme a LGPD, assinale a alternativa correta.

- A) O acesso público elimina todos os direitos do titular sobre os dados.
- B) Dados tornados públicos pelo titular podem ser tratados para qualquer finalidade empresarial ou estatal, sem restrições.
- C) O tratamento de dados cujo acesso é público deve considerar finalidade, boa-fé e interesse público que justificaram sua disponibilização.
- D) Dado público passa automaticamente a ser dado anonimizado.
- E) O Poder Público deve impedir qualquer uso de dados pessoais disponíveis em portais oficiais.

Questão 19

Uma unidade deseja publicar relatório nominal de produtividade com dados detalhados de servidores, partes e advogados, incluindo CPF, telefone e endereço, para demonstrar transparência administrativa. A alternativa mais compatível com LGPD e transparência pública é:

- A) publicar integralmente, pois transparência pública sempre prevalece sobre proteção de dados pessoais.
- B) suprimir qualquer informação do relatório, pois a LGPD impede publicidade de atos administrativos.
- C) publicar apenas mediante consentimento de todos os envolvidos, ainda que haja obrigação legal de transparência.
- D) avaliar finalidade, base legal, necessidade, proporcionalidade e possibilidade de anonimização, agregação ou ocultação de dados excessivos.
- E) trocar o formato PDF por CSV, pois formato aberto elimina o problema jurídico.

Questão 20

No desenvolvimento de um sistema com formulário de cadastro, a equipe decide coletar todos os campos 'por precaução', incluindo dados que talvez sejam úteis no futuro, mas sem finalidade atual definida. A decisão contraria de modo mais direto o princípio da:

- A) necessidade, porque os dados devem ser limitados ao mínimo necessário para a finalidade definida.
- B) portabilidade, porque todo dado deve ser exportado em formato interoperável.
- C) proteção do crédito, porque o cadastro pode envolver relação financeira.
- D) livre iniciativa, porque a coleta amplia a inovação tecnológica.
- E) anonimização, porque todo dado deve ser coletado já anônimo.

12. Gabarito resumido

Gabarito

1-C; 2-D; 3-B; 4-C; 5-A; 6-B; 7-D; 8-B; 9-D; 10-A; 11-C; 12-C; 13-C; 14-D; 15-A; 16-B; 17-A; 18-C;
19-D; 20-A

13. Comentários completos

Questão 1 - Gabarito: C

A correta é C: devolver campos não usados pela tela aumenta exposição e afronta o princípio da necessidade. A alternativa A seduz porque HTTPS protege o transporte, mas criptografia não legitima excesso de dados. B erra ao dizer que necessidade não é afetada por dados internos. D erra porque dados cadastrais comuns também são pessoais. E erra porque consentimento não é a única análise, sobretudo em ambiente institucional.

Questão 2 - Gabarito: D

A correta é D: o fornecedor, sem decidir finalidade e atuando conforme instruções, tende a ser operador. A seduz por falar em comunicação, mas encarregado é canal institucional, não qualquer fornecedor. B confunde quem trata com quem é titular. C exagera: terceiro não vira controlador automaticamente. E é sem aderência: fornecedor não é autoridade nacional.

Questão 3 - Gabarito: B

A correta é B: I e II estão corretas; III está errada porque pseudonimização não equivale necessariamente a anonimização. A erra ao ignorar II. C e D incluem III ou excluem I indevidamente. E erra porque afirma que todo dado pseudonimizado sai do regime da LGPD.

Questão 4 - Gabarito: C

A correta é C: o Poder Público pode tratar dados para finalidade pública, interesse público e competências legais, observados princípios e transparência. A erra porque interesse público não dispensa LGPD. B erra porque consentimento não é base única. D erra porque transparência não substitui segurança. E erra porque a LGPD também se aplica sem compartilhamento privado.

Questão 5 - Gabarito: A

A sequência correta é 4 - 1 - 2 - 3. Titular é a pessoa natural; controlador decide; operador trata em nome; encarregado atua como canal. As demais alternativas trocam papéis próximos, especialmente operador e controlador ou encarregado e titular.

Questão 6 - Gabarito: B

A correta é B: dados sintéticos, mascaramento ou pseudonimização e restrição de acesso reduzem risco e respeitam necessidade. A erra porque desenvolvimento também pode ser tratamento. C erra porque nome pode identificar e CPF não é o único dado pessoal. D traz controle administrativo, mas dispensa indevidamente controles técnicos. E erra porque planilhas também podem ser banco de dados ou suporte de tratamento.

Questão 7 - Gabarito: D

A correta é D: dado biométrico vinculado a pessoa natural é dado sensível. A pode ser pessoal se vinculado, mas não é sensível por si. B é genérico de unidade, não necessariamente pessoa natural. C afasta associação a pessoa natural. E descreve dado anonimizado/aleatório não reidentificável.

Questão 8 - Gabarito: B

A correta é B: logs podem conter dado pessoal e exigem finalidade, retenção, acesso e segurança. A erra por tratar log como puramente técnico. C erra porque auditoria pode justificar retenção. D erra porque retenção ilimitada sem política afronta necessidade. E erra porque dados pessoais comuns também importam.

Questão 9 - Gabarito: D

A incorreta é D: dado pessoal é informação relacionada a pessoa natural, não pessoa jurídica. A está correta: pode ser meio físico ou digital. B está correta: dispensa de consentimento não elimina princípios. C está correta: dado público exige finalidade e boa-fé. E está correta: tratamento é conceito amplo.

Questão 10 - Gabarito: A

A correta é A: agregação/anonimização efetiva pode afastar identificação razoável. B erra pelo absolutismo: nem todo dado derivado continua pessoal. C erra porque estatística pública não é ilícita por si. D erra porque

o tratamento anterior ainda exige finalidade e controles. E erra porque anonimização é relevante para a LGPD.

Questão 11 - Gabarito: C

A correta é C: compartilhamento entre órgãos exige finalidade pública, competência, transparência, escopo mínimo e segurança. A erra por autorizar troca ampla. B reduz conformidade a TLS. D erra porque consentimento nem sempre é necessário quando há obrigação legal. E erra porque compartilhamento pode ser permitido sem decisão judicial individual.

Questão 12 - Gabarito: C

A correta é C: o encarregado recebe reclamações, comunicações da ANPD e orienta funcionários/contratados. A atribui decisão de controlador. B confunde encarregado com operador. D inverte a relação com a ANPD. E exagera atribuição técnica que não decorre da LGPD.

Questão 13 - Gabarito: C

A correta é C: segurança é necessária, mas não substitui base legal e princípios. A e B erram por transformar controle técnico em fundamento jurídico. D cria restrição falsa apenas a crianças. E seduz por citar HSM, mas o nível da chave não resolve finalidade, base legal e necessidade.

Questão 14 - Gabarito: D

A correta é D: deve-se avaliar finalidade, base de conservação, temporalidade e riscos antes de eliminar, anonimizar ou restringir. A normaliza retenção indefinida. B erra por apagar sem avaliar obrigações legais. C viola proteção de dados. E erra porque backup e legado também exigem governança.

Questão 15 - Gabarito: A

A correta é A: a LGPD traz regra de melhor interesse e consentimento específico/destacado para crianças, com nuances legais. B ignora previsão expressa. C dispensa transparência indevidamente. D não tem base: adolescentes não são automaticamente anônimos. E limita indevidamente o melhor interesse a apps comerciais.

Questão 16 - Gabarito: B

A correta é B: clareza sobre tratamento, finalidade, duração, controlador e compartilhamento concretiza transparência e livre acesso. A mistura direitos/bases sem foco. C fala em anonimização e bloqueio, que não são a essência do portal. D e E trazem fundamentos fora do núcleo descrito.

Questão 17 - Gabarito: A

A correta é A: RIPD descreve tratamentos de risco e medidas de mitigação. B é absurdo operacional e inseguro, mas seduz por 'auditoria'. C ignora riscos aos titulares. D confunde relatório com política de segurança. E é o oposto de conformidade: autorização genérica não resolve LGPD.

Questão 18 - Gabarito: C

A correta é C: dado público deve respeitar finalidade, boa-fé e interesse público. A erra ao eliminar direitos do titular. B erra por permitir qualquer finalidade. D confunde publicidade com anonimização. E erra por proibir qualquer uso, quando o tratamento pode ser legítimo.

Questão 19 - Gabarito: D

A correta é D: transparência deve ser compatibilizada com finalidade, base legal, necessidade e minimização, podendo usar anonimização, agregação ou ocultação. A absolutiza a publicidade. B absolutiza a privacidade. C torna consentimento sempre obrigatório. E muda formato, mas não resolve excesso de dados.

Questão 20 - Gabarito: A

A correta é A: coletar dados sem finalidade atual por 'precaução' viola necessidade e também pode atingir finalidade. B fala de portabilidade, não do excesso. C é uma base específica sem relação direta. D invoca livre iniciativa de forma deslocada. E confunde coleta mínima com anonimização.

14. Fechamento da aula

Para a prova, esta aula deve deixar três reflexos: primeiro, identificar dado pessoal e dado sensível no contexto técnico; segundo, diferenciar base legal, princípio e controle de segurança; terceiro, aplicar LGPD ao ciclo de vida do dado em sistemas públicos, sem cair em respostas absolutas.

O próximo avanço natural da trilha é Aula 3 - Gestão de identidade e acesso: IAM - Identity and Access Management, RBAC - Role-Based Access Control, ABAC - Attribute-Based Access Control, privilégios e ciclo de vida. A ponte entre as aulas é direta: controle de acesso é medida de segurança da LGPD, mas também é disciplina técnica própria em IAM.

15. Fontes consultadas

1. Edital nº 10/2026 retificado - TJSC - Analista de Sistemas - Fundação Getulio Vargas: disciplina Segurança da Informação e Governança de TI.
2. Lei nº 13.709/2018 - Lei Geral de Proteção de Dados Pessoais - LGPD, especialmente arts. 1º a 16, 18, 20, 23, 27, 29, 30, 38, 39, 41, 44 e 50.
3. Autoridade Nacional de Proteção de Dados - ANPD. Guia: Tratamento de Dados Pessoais pelo Poder Público.
4. Autoridade Nacional de Proteção de Dados - ANPD. Guia orientativo sobre agentes de tratamento e encarregado; guia sobre atuação do encarregado.
5. Provas públicas da FGV de Tecnologia da Informação, Segurança da Informação e cargos correlatos, consultadas apenas para calibração de estilo, densidade e formatos de cobrança, sem cópia literal de questões.